

HRITIK VIJAY

Security Engineer

+91 8700388609 | hire@hritik.sh | hritik.sh | github.com/hritik14

SUMMARY

Senior security engineer, 4+ years formal experience, 8+ years in security and open source. Co-creator of SupplyShield (BlackHat Arsenal 3x — EU 2023, MEA 2024, Asia 2025) and Open Source Summit NA speaker. Published CVEs in cpp-httplib, co-maintainer of VulnerableCode, co-drafted the vers specification alongside Package-URL. Deep experience building DevSecOps programs, hardening CI/CD against supply chain attacks, and performing code-level reviews across Python, Java, and Go.

SECURITY RESEARCH & DISCLOSURES

- CVE-2026-22776 (GHSA-h934-98h4-j43q) – Discovered a high-severity Denial of Service vulnerability in cpp-httplib via zip bomb decompression (CVSS 8.7); unsafe handling of compressed HTTP request bodies allowed attackers to exhaust server memory.
- CVE-2026-21428 (GHSA-wpc6-j37r-jcx7) – Discovered a CRLF injection vulnerability in cpp-httplib enabling HTTP header injection and SSRF attacks via unsanitized headers combined with HTTP/1.1 pipelining.
- CVE-2020-6862 – Discovered and reported an information disclosure vulnerability in ZTE routers (CVSS Base Score: 7.3); published on Exploit-DB.
- Xen Project Hall of Fame – Recognized for documenting an exploit in the Xen hypervisor.

TALKS & PRESENTATIONS

- **BlackHat Asia Arsenal 2025** — *SupplyShield: Protecting Your Software Supply Chain* (co-presented).
- **BlackHat MEA Arsenal 2024** — *SupplyShield: Protecting Your Software Supply Chain* (co-presented).
- **BlackHat EU Arsenal 2023** — *SupplyShield: Protecting Your Software Supply Chain* — first public release (co-presented).
- **Nullcon Goa 2025** — *Securing the Chains: Building Defensive Layers for Software Supply Chains* (co-presented).
- **Open Source Summit North America 2022** — *PURL and vers: Universal Package URL and Version Ranges for Dependencies and Vulnerabilities*. Co-presented with Philippe Ombredanne (AboutCode).
- **BSides Noida** — *DNS Rebinding Toolkit*. Open-source attack toolkit for bypassing NAT-based network segmentation.

EXPERIENCE

Sr. Product Security Engineer June 2022 – Present

Dreamplug Technologies Pvt Ltd (CRED) Bangalore, India

- Architected and led the DevSecOps charter across 1,800+ repositories, implementing custom SAST detections, automated alerting pipelines, and supply chain vulnerability scanning at scale.
- Built and owned the organization's primary Application Security Posture Management (ASPM) platform, providing centralized visibility into security risk across all services and infrastructure.
- Designed and hardened CI/CD pipelines with dependency verification, signed attestations, and automated policy enforcement to mitigate supply chain attack vectors.
- Performed in-depth source code security reviews for backend services in Python, Java, and Golang, identifying critical vulnerabilities before production deployment.
- Led cross-functional learning sessions on enterprise Java security, supply chain security, and AI security, and drove secure cloud infrastructure practices on AWS: network segmentation, access control, and container security hardening.

Maintainer & Core Contributor October 2021 – Present

AboutCode / VulnerableCode (Open Source) Remote

- Maintain and develop VulnerableCode, an industry-reference open-source vulnerability database and software composition analysis (SCA) platform.
- Co-drafted the vers specification, a universal way to parse and compare package versions across ecosystems, alongside Package-URL (PURL), emerging as industry standards for dependency and vulnerability identification.
- Google Summer of Code 2021 student → mentor. Refactored the core engine for performance, maintained CI pipelines, integrated global advisory sources.
- Active collaboration with global contributors on advisory ingestion, data accuracy, and ecosystem-wide supply chain security tooling.

Software Development Engineer October 2021 – May 2022

Wavicle Technologies / LimeChat Bangalore, India

- Developed and managed real-time chatbot automations deployed on AWS EKS Kubernetes clusters, gaining hands-on experience with container orchestration, networking, and cloud infrastructure at scale.
- Maintained service reliability through detailed root cause analyses, Infrastructure-as-Code practices, and proactive monitoring using Python, PostgreSQL, and Bash.

OPEN SOURCE & PROGRAMS

Python Developer – Google Summer of Code June 2021 – August 2021

AboutCode / VulnerableCode Remote

- Refactored the project's core engine for significant performance improvements in Python/Django; maintained CI pipelines (GitHub Actions, Travis CI) and improved Docker container builds.
- Integrated multiple global security advisory data sources and authored project documentation deployed on Read the Docs.

Open Source Contributions

Active contributor to The Linux Kernel, scancode.io, rclone, Kong (Golang), and changedetection.io. Contributions span security patches, performance improvements, and feature development.

TECHNICAL SKILLS

Languages: Python, Golang, Java, TypeScript, Lua, Bash, SQL, C (AVR/embedded)

Security: Supply Chain Security, SAST, SCA, ASPM, Threat Modeling, Penetration Testing, Code Review, OWASP

Cloud & Infra: AWS, Kubernetes (EKS), Docker, CI/CD (GitHub Actions, Travis CI, GitOps)

Tools: Burp Suite, Wireshark, Metasploit, Git, Linux Administration, eBPF

EDUCATION

Bachelor of Technology – Computer Science 2018 – 2022